

ADR 0133 — Forge reads have their own credential and wait boundary

- Date: 2026-09-06
- Status: Accepted, first slice of #89
- Supersedes in part: [ADR 0122](#), whose no-HTTP-client premise applied to Git transfers.
- Related: [ADR 0128](#), [ADR 0115](#).

Context

Read-only GitHub PR summaries are the first server-owned HTTP consumer of the credential resolver. Git transfers continue to use the contained helper path; this feature must not put provider dependencies into the local Git graph/read pipeline. #89 permits GitHub-shaped types at the handler boundary only.

Decision

`handlers::forge` owns the GitHub adapter and its private response types. `git-vista-protocol::forge` contains only repository metadata, PR summary fields, availability, pagination, and capabilities. No speculative generic provider trait or provider SDK is required for one implementation.

The server process calls `state::credential_token()` through the existing resolver interface, on a blocking worker with a two-second response budget. A process-wide semaphore admits at most one such worker. A timed-out worker retains its permit until it exits, so repeated panel opens cannot create an unbounded population of blocked keyring calls. This does not change or bypass the resolver's precedence; a stuck resolver makes provider reads unavailable. The independent Settings work in #698 does not supply operation credentials.

The token lives in server memory and a sensitive HTTP authorization header. Only the fixed `https://api.github.com` origin receives it. The HTTP client has TLS, a three-second connect/eight-second total HTTP deadline, no redirects and no ambient proxies. No child process receives the token. The exact origin URL is read through a neutral Git adapter, then HTTPS/SSH/scp GitHub forms are parsed at the handler boundary and strictly validated as two safe path components. Lossy display-link normalization is not used. Upstream `html_url` and Link destinations never become request destinations. Web links are constructed from the validated repository and numeric PR number. Exact-token redaction covers titles; a repository name containing the resolved token fails closed. Upstream bodies, headers, and HTTP error text are never logged or forwarded. A token reaching a response would require bypassing this projection/redaction or adding another unsanitized field; dynamic canary tests inspect serialized bytes, not only a type shape.

The loopback-only, authenticated `GET /api/forge/pulls?repo=<opaque-id>&page=N` is called only by an explicitly opened PR panel. It accepts pages 1–10,000, requests 30 records, caps decoded HTTP bodies at 1 MiB, and returns a next-page number only for a validated next Link. A page cap is a deliberate bound: users must use the provider website beyond it. Numbered pages are live snapshots; concurrent provider edits can move records between pages. There is no claim of snapshot consistency. Requests are admitted fail-fast, at most two concurrently. No repository coordinator is held across provider I/O.

403/404/401 without clear rate-limit evidence report uncertain access, not a claim that a repository is absent or a token is invalid. 429, or 403 with Retry-After/exhausted remaining quota, starts a cooldown. A successful response with exhausted quota also starts it. Cooldowns honor numeric Retry-After or reset epoch, default to 60 seconds, and are bounded to one day. The process shares a conservative deadline across all repositories and token changes; only the deadline is retained, never provider payloads or token identifiers. This may temporarily pause an

unaffected token after a Settings change. It prevents repeated requests from this process; it cannot coordinate another process using the same token.

Every response is `no-store`. No server cache or persistence exists; cache opt-in is deferred. The browser holds only the displayed page, clears it on close or selection change, and rejects old request epochs. Graph loading never awaits it.

Scope and consequences

This slice offers open PR number/title/draft state and canonical links. Capabilities explicitly report checks and reviews unavailable; it does not close #89. No enterprise hosts, checks/review details, mutation operations, polling, cache opt-in, or automatic retries are included. The new Rust TLS HTTP dependency supersedes ADR 0122 only for this API boundary.

A real socket fixture stalls the provider while the real sandboxed local Git read adapter completes on a single-thread runtime. Contract fixtures include extra production fields, null nested repositories/users, drafts, Unicode, malicious links, errors, malformed payloads and oversized bodies. Browser tests exercise the topbar entry, summaries, paging, pending-provider close, and a fresh fetch after reopening. Pure frontend decisions remain host-tested per ADR 0115.

Alternatives

Putting provider work into `/api/frame` would make outages part of graph load. Running the resolver inline would block an async worker on a locked keyring. A timeout without admission control would leak blocking workers. Following provider URLs or redirects would widen the credential destination boundary. Caching privately returned pages would require explicit retention/invalidation policy; that is deferred rather than silently enabled.

References

- [GitHub list pull requests](#)
- [GitHub rate limits](#)
- [reqwest ClientBuilder](#)